

STRATUM CAPITAL BANK

Enterprise Governance & Risk Framework

CHAPTER 9

Business Continuity, Disaster Recovery  
& Crisis Management Framework

|                       |                                                           |
|-----------------------|-----------------------------------------------------------|
| Version:              | 5.4.1                                                     |
| Classification:       | CONFIDENTIAL – Internal Use Only                          |
| Effective Date:       | 1 January 2025                                            |
| Next Review:          | 31 December 2025                                          |
| Policy Owner:         | Chief Risk Officer / Business Continuity Manager          |
| Approved By:          | Board Risk & Compliance Committee                         |
| Regulatory Reference: | PRA SS1/21, FCA SYSC 15A, DORA Art. 11–14, ISO 22301:2019 |

*This document is the property of Stratum Capital Bank. Unauthorised disclosure, reproduction or distribution is strictly prohibited. Recipients are reminded of their obligations under applicable data protection and confidentiality legislation.*

## 9.1 Purpose

This chapter of the Enterprise Governance & Risk Framework ("Framework") sets out the overarching principles, governance structures, operational requirements and minimum standards applicable to Business Continuity Management ("BCM"), Disaster Recovery ("DR") and Crisis Management across Stratum Capital Bank ("the Bank") and all entities within its regulatory perimeter. The Framework has been developed in alignment with the Bank's obligations under the Prudential Regulation Authority ("PRA") Supervisory Statement SS1/21, the Financial Conduct Authority ("FCA") Systems and Controls sourcebook SYSC 15A, the Digital Operational Resilience Act ("DORA") and the international standard ISO 22301:2019 (Security and resilience - Business continuity management systems).

### 9.1.1 Objectives

The primary objectives of this Framework are to:

- Ensure the continued delivery of critical banking services during and following any disruptive event, irrespective of cause, severity or duration;
- Protect the financial soundness, operational integrity and reputational standing of the Bank;
- Safeguard customer assets, data and continuity of access to banking services at all times;
- Establish clearly defined roles, responsibilities and escalation protocols for managing business disruption at all organisational levels;
- Meet all regulatory expectations and statutory obligations relating to operational resilience, business continuity and disaster recovery;
- Provide a framework for continuous improvement through structured testing, exercising, post-incident review and lessons-learned integration;
- Align the Bank's resilience posture with international best practice standards and peer benchmarks;
- Enable rapid, co-ordinated and transparent communication with regulators, customers, media and other stakeholders during periods of disruption.

### 9.1.2 Operational Resilience

Operational resilience is the ability of the Bank to prevent, adapt, respond to, recover from and learn from operational disruptions. The Bank adopts the joint PRA/FCA definition and commits to identifying its Important Business Services ("IBS"), setting appropriate impact tolerances, and demonstrating through rigorous scenario testing that those tolerances can be maintained even in severe but plausible disruption scenarios. Operational resilience is not a one-time project but a continuous management discipline embedded in strategy, risk appetite, change management and assurance activities.

### 9.1.3 Critical Banking Services

The Bank has identified the following services as critical banking services requiring the highest level of continuity protection:

- Retail and commercial current account operations and payment processing;
- Online and mobile banking platforms;
- Treasury and financial markets dealing;
- Lending and credit operations;
- Card services and ATM network management;
- Custody and securities settlement;
- Trade finance and documentary credit operations;
- Regulatory reporting and prudential returns.

Each critical banking service is subject to a formally documented Business Impact Analysis, Recovery Time Objective ("RTO") and Recovery Point Objective ("RPO") as set out in Section 9.3.

### 9.1.4 Customer Protection

The Bank places the protection of its customers and their assets at the heart of its resilience strategy. The Bank is committed to ensuring that customers are not placed at risk of material harm as a result of operational disruption, and that clear, timely and accurate communication is provided to customers in the event of any service interruption. The Bank's approach to customer protection in the context of operational disruption is informed by the FCA's Consumer Duty and the principle that the Bank must act to deliver good outcomes for retail customers at all times.

### 9.1.5 Regulatory Compliance

This Framework has been designed to satisfy the requirements of the following regulatory instruments and guidance:

| Regulatory Instrument                                                          | Issuing Authority                              | Key Obligation                                                  |
|--------------------------------------------------------------------------------|------------------------------------------------|-----------------------------------------------------------------|
| PRA SS1/21 – Operational Resilience                                            | Prudential Regulation Authority                | Impact tolerances, self-assessment, scenario testing            |
| FCA SYSC 15A – Operational Resilience                                          | Financial Conduct Authority                    | Important Business Services, continuity of service to consumers |
| DORA (EU) 2022/2554 – Articles 11–14                                           | European Parliament                            | ICT risk management, continuity policy, backup, DR testing      |
| ISO 22301:2019                                                                 | International Organisation for Standardisation | BCM system design, implementation and certification             |
| Basel Committee on Banking Supervision – Principles for Operational Resilience | Bank for International Settlements             | Board governance, scenario analysis, third-party risk           |
| PRA SS2/21 – Outsourcing & Third Parties                                       | Prudential Regulation Authority                | Critical service provider resilience obligations                |
| The Banking Act 2009                                                           | HM Parliament                                  | Systemic risk notification, Special Resolution Regime           |

## 9.2 Governance Structure

The governance of Business Continuity, Disaster Recovery and Crisis Management at the Bank operates through a tiered accountability model that spans Board-level oversight through to operational delivery. All roles described in this section carry formal responsibilities documented in individual position mandates, terms of reference and performance objectives.

### 9.2.1 Board of Directors

The Board of Directors ("Board") bears ultimate accountability for the Bank's operational resilience. Specific Board responsibilities include:

- Approving the Business Continuity and Operational Resilience Policy and any material amendments thereto;
- Reviewing and challenging annual resilience self-assessments presented by the Chief Risk Officer;
- Approving the Bank's impact tolerances for each Important Business Service;
- Satisfying itself, at least annually, that the Bank has the capability to remain within impact tolerances during a severe but plausible operational disruption;
- Receiving and acting upon material incident reports, including regulatory notifications arising from operational events;
- Exercising its responsibilities as set out in the UK Corporate Governance Code and PRA Fundamental Rule 6.

### 9.2.2 Chief Executive Officer

The Chief Executive Officer ("CEO") is accountable to the Board for the implementation of the operational resilience strategy and is personally responsible for the Bank's response to a Category 1 crisis event. The CEO chairs the Crisis Management Executive Committee during declared crises and has authority to mobilise all organisational resources necessary to protect critical banking services.

### 9.2.3 Chief Risk Officer

The Chief Risk Officer ("CRO") is the designated Senior Management Function holder responsible for operational resilience under the Senior Managers and Certification Regime ("SM&CR"). The CRO's specific responsibilities include:

- Owning and maintaining this Framework and all subordinate BCM and DR policies;
- Presenting the annual operational resilience self-assessment to the Board;
- Escalating material threats to operational resilience to the CEO and Board;
- Overseeing the Business Continuity Manager and IT Operations function;
- Maintaining regulatory relationships with the PRA and FCA on matters of operational resilience;
- Commissioning and reviewing independent internal audit and external assurance activities.

### 9.2.4 Business Continuity Manager

The Business Continuity Manager ("BCM Manager") is responsible for the day-to-day management, maintenance and continuous improvement of the Bank's BCM programme. Responsibilities include:

- Maintaining all Business Continuity Plans ("BCPs") and Disaster Recovery Plans ("DRPs") in current, tested and validated condition;
- Coordinating Business Impact Analyses across all business units on an annual basis;

- Scheduling, executing and reporting on all BCP and DR testing exercises;
- Maintaining the Business Continuity Management System ("BCMS") in conformance with ISO 22301:2019;
- Managing the Crisis Management team and War Room activation protocols;
- Reporting monthly to the CRO and quarterly to the Risk & Compliance Committee.

### 9.2.5 IT Operations

---

The Head of IT Operations is responsible for the technical delivery of disaster recovery capabilities, including the management of primary and secondary data centres, cloud recovery environments, backup infrastructure and recovery automation. IT Operations works in close partnership with the BCM Manager to ensure technical recovery objectives are achievable and validated.

### 9.2.6 Cyber Security

---

The Chief Information Security Officer ("CISO") is responsible for cyber incident response, integration of cyber threat intelligence into resilience planning, and the management of the Cyber Security Incident Response Plan ("CSIRP"). The CISO has independent escalation rights directly to the Board in the event of a material cyber incident.

### 9.2.7 Business Units

---

Each business unit is required to maintain a current, tested and approved Business Continuity Plan in the format prescribed by the BCM Manager. Business Unit Heads are personally accountable for the resilience of processes within their remit and must nominate a Deputy Business Continuity Coordinator for each critical function. Business units must complete annual BIA submissions, participate in testing exercises and implement all corrective actions arising from post-incident reviews within agreed timescales.

### 9.2.8 Third Parties and Outsourced Service Providers

---

Third parties providing material services to the Bank are subject to contractual requirements to maintain BCPs and DRPs meeting or exceeding the Bank's minimum standards. The Bank's vendor resilience requirements are set out in Section 9.9. Third-party resilience obligations are governed by the Bank's Third Party and Outsourcing Policy and are subject to periodic due diligence review by the CRO.

## 9.3 Business Impact Analysis

The Business Impact Analysis ("BIA") is the foundation of the Bank's BCM programme. The BIA provides a systematic, evidence-based assessment of the potential consequences of disruption to each business process, enabling the Bank to prioritise its recovery investments and set appropriate recovery objectives. The BIA is conducted annually or following any material change to the Bank's operating model, technology landscape or regulatory environment.

### 9.3.1 Critical Processes

The BIA process identifies and categorises all business processes according to their criticality. Processes are assessed against the following criteria: regulatory obligation, customer impact, financial exposure, reputational risk and legal liability. The current Critical Process Register includes:

| Process Category            | Examples                                             | Criticality Tier   |
|-----------------------------|------------------------------------------------------|--------------------|
| Payments & Settlement       | CHAPS, BACS, SWIFT, internal transfers               | Tier 1 – Critical  |
| Customer Account Management | Account opening, KYC, account servicing              | Tier 1 – Critical  |
| Online & Mobile Banking     | Internet banking, mobile app, API banking            | Tier 1 – Critical  |
| Treasury Operations         | FX dealing, repo, money markets                      | Tier 1 – Critical  |
| Lending & Credit            | Mortgage origination, corporate lending, collections | Tier 2 – Important |
| Regulatory Reporting        | PRA returns, FCA reporting, CASS reconciliation      | Tier 1 – Critical  |
| Card Services               | Debit/credit issuance, authorisation, disputes       | Tier 2 – Important |
| Branch Operations           | Cash handling, in-branch services                    | Tier 2 – Important |
| HR & Payroll                | Staff payroll processing                             | Tier 3 – Standard  |
| Procurement & Finance       | Purchase to pay, general ledger, accounts payable    | Tier 3 – Standard  |

### 9.3.2 Maximum Tolerable Downtime

Maximum Tolerable Downtime ("MTD") is defined as the maximum duration beyond which disruption to a process would cause unacceptable consequences to customers, the Bank or the financial system. MTD values are validated during the annual BIA cycle and approved by the CRO. MTD values inform the setting of Recovery Time Objectives and must always exceed the RTO to provide an adequate buffer.

### 9.3.3 Recovery Time Objectives

The Recovery Time Objective ("RTO") specifies the maximum acceptable time from disruption to full or partial restoration of a process or system. RTOs are set below MTD values to ensure the Bank can restore operations within acceptable limits. The following table sets out the Bank's approved RTOs for Tier 1 and Tier 2 processes:

| Process / System                | MTD      | RTO        | RPO        |
|---------------------------------|----------|------------|------------|
| Payment processing (CHAPS/BACS) | 2 hours  | 1 hour     | 15 minutes |
| Core banking system             | 4 hours  | 2 hours    | 30 minutes |
| Online & mobile banking         | 4 hours  | 2 hours    | 1 hour     |
| Treasury dealing platform       | 2 hours  | 1 hour     | 15 minutes |
| Regulatory reporting systems    | 8 hours  | 4 hours    | 1 hour     |
| Email & communications          | 8 hours  | 4 hours    | 4 hours    |
| Card authorisation              | 1 hour   | 30 minutes | 5 minutes  |
| CASS reconciliation             | 24 hours | 8 hours    | 4 hours    |
| HR & payroll                    | 72 hours | 48 hours   | 24 hours   |
| General ledger                  | 24 hours | 12 hours   | 4 hours    |

### 9.3.4 Recovery Point Objectives

The Recovery Point Objective ("RPO") specifies the maximum acceptable data loss measured in time prior to a disruption. RPOs drive the Bank's backup frequency and data replication strategy. Where RPOs require near-zero data loss, synchronous replication must be employed. All RPOs are validated during DR testing exercises as documented in Section 9.11.

### 9.3.5 Financial Impact

The BIA quantifies the financial consequences of process disruption across the following dimensions: direct revenue loss; regulatory fines and penalties; compensation costs; incident management costs; and costs of enhanced monitoring. Financial impact thresholds that trigger escalation to the Crisis Management Executive Committee are reviewed annually by the CFO and CRO in consultation with the Board Risk Committee.

### 9.3.6 Operational Impact

Operational impacts assessed during the BIA include: capacity to process customer transactions; ability to meet payment system obligations; availability of key staff and skills; functionality of critical systems and infrastructure; and the ability to fulfil regulatory reporting obligations. Operational impact is assessed on a tiered scale from Minimal (1) to Catastrophic (5), with scores of 4 or above triggering immediate escalation.

### 9.3.7 Legal and Regulatory Impact

The BIA evaluates potential legal and regulatory consequences of disruption, including: breach of payment system rules; failure to meet reporting deadlines; CASS regulatory obligations; breach of customer protection regulations; and potential criminal liability under the Financial Services and Markets Act 2000. Material legal exposures are reported to the General Counsel and escalated to the Board as appropriate.

### 9.3.8 Customer Impact

---

The Bank assesses customer impact across four dimensions: inability to access funds; inability to make or receive payments; loss of data; and inability to access banking services. Customer impact drives the Bank's impact tolerance settings for its Important Business Services under the PRA/FCA operational resilience regime. Where customer impact thresholds are breached, the Bank is required to notify the relevant regulator within the timeframes specified in Section 9.12.



## 9.4 Business Continuity Planning

The Bank's Business Continuity Plans ("BCPs") provide the operational procedures required to maintain or rapidly restore critical business processes following a disruptive event. BCPs are maintained at business unit, divisional and enterprise level, with clear escalation pathways between each tier. All BCPs are subject to annual review, testing and Board-level approval.

### 9.4.1 Department Plans

Each business unit is required to maintain a departmental BCP covering: priority activities and minimum operating levels; staff contact lists and deputisation arrangements; critical system access requirements; manual processing workarounds; alternative working locations; and communication protocols. Departmental BCPs must be submitted to the BCM Manager for review and registration by 31 March each year and updated within 10 business days of any material change.

### 9.4.2 Alternative Locations

The Bank maintains the following alternative working locations to enable continuity of operations in the event that primary premises become unavailable:

| Location                       | Type             | Capacity         | Activation Time | Systems Available                 |
|--------------------------------|------------------|------------------|-----------------|-----------------------------------|
| London Disaster Recovery Site  | Warm standby     | 250 workstations | 4 hours         | Full core banking, trading, email |
| Manchester Regional Hub        | Secondary office | 150 workstations | 2 hours         | Core banking, email, telephony    |
| Edinburgh Operations Centre    | Secondary office | 80 workstations  | 4 hours         | Core banking, email               |
| Third-party DR Suite (Sungard) | Contracted DR    | 200 workstations | 8 hours         | Configurable per contract         |

All alternative locations are subject to quarterly connectivity testing and annual full occupation exercises. Access arrangements and equipment inventories are maintained in the Business Continuity Resource Register and reviewed semi-annually.

### 9.4.3 Manual Processing

Manual Processing Procedures ("MPPs") have been documented for all Tier 1 and Tier 2 processes to enable operations to continue in the event of system failure. MPPs define the minimum staff required, paper-based or offline procedures, data capture methods and reconciliation requirements. MPPs are tested during tabletop exercises and updated following any system change that affects the relevant process. The Bank maintains a manual processing kit at each alternative location, containing current procedure guides, blank forms and reconciliation templates.

### 9.4.4 Remote Working

The Bank's remote working capability has been designated as a primary continuity strategy for business disruption events that do not affect the Bank's technology infrastructure. The following standards apply to remote working arrangements activated under BCPs:

- All staff with critical roles must have been pre-equipped with approved remote working technology including encrypted laptops, VPN access and multi-factor authentication;
- Remote working capacity has been designed to accommodate 100% of office-based headcount simultaneously;
- All remote access is governed by the Remote Access Security Policy and subject to continuous monitoring by the Cyber Security team;
- Productivity and availability expectations during remote working activation are defined in the Remote Working BCP Supplement;
- All remote working sessions must be conducted using Bank-approved equipment and networks only.

### 9.4.5 Staff Availability

---

Staff availability planning ensures the Bank maintains sufficient personnel to operate critical processes during disruption events, including those caused by pandemic, civil unrest or other large-scale societal events. The Bank's staff availability strategy includes:

- Maintenance of a Critical Staff Register identifying the minimum complement required for each Tier 1 process;
- Cross-training programmes ensuring at least two competent individuals for each critical role;
- Succession plans for all senior management positions with formal knowledge transfer obligations;
- Mutual aid agreements with partner institutions for specialist skills in extreme scenarios;
- Annual staff availability testing as part of BCM exercises.

### 9.4.6 Communication Plans

---

Communication plans are maintained to ensure timely, accurate and appropriate communications during business disruption events. Communication plans cover: internal staff notification; customer communications; regulatory notifications; media relations; Board and senior management briefings; and third-party supplier communications. Full detail of communication protocols is set out in Section 9.12.

### 9.4.7 Recovery Priorities

---

In the event of resource constraints during a recovery operation, the Bank will prioritise restoration activities in the following sequence:

1. Safeguard customer funds and prevent financial loss;
2. Restore payment system connectivity (CHAPS, BACS, SWIFT);
3. Restore core banking system availability;
4. Restore online and mobile banking access;
5. Restore treasury and financial markets dealing capabilities;
6. Restore card services and ATM network;
7. Restore regulatory reporting systems;
8. Restore all remaining Tier 2 and Tier 3 processes in BIA priority order.

## 9.5 Disaster Recovery Framework

The Bank's Disaster Recovery Framework provides the technical architecture, procedures and governance required to recover IT systems, applications and data following a major disruptive event. The DR Framework operates in close alignment with the BCM programme and is designed to meet the RTOs and RPOs set out in Section 9.3.

### 9.5.1 Primary Data Centre

The Bank's primary data centre ("PDC") is located in Slough, United Kingdom, and hosts all production systems, databases and network infrastructure. The PDC is rated to Tier III standards under the Uptime Institute classification and is equipped with: N+1 redundant power supply including UPS and diesel generator backup with 72-hour fuel reserves; dual fibre connectivity from independent providers with automatic failover; N+1 redundant cooling infrastructure; physical security controls including biometric access, CCTV and 24/7 security personnel; and environmental monitoring systems with real-time alerting.

### 9.5.2 Secondary Data Centre

The Bank's secondary data centre ("SDC") is located in Manchester, United Kingdom, maintaining a minimum physical separation of 200 kilometres from the PDC to ensure geographic diversity against regional disaster scenarios. The SDC operates in an active-active configuration for Tier 1 systems, ensuring immediate failover capability. The SDC is equipped to equivalent Tier III standards and is capable of sustaining full Bank operations independently for a minimum of 30 days without intervention from the PDC.

### 9.5.3 Cloud Recovery

The Bank maintains a cloud-based tertiary recovery environment within a Government-approved, UK-sovereign cloud region. The cloud recovery environment is designed to serve as a fallback in the event of simultaneous failure of both the PDC and SDC, and for selected systems where cloud-native deployment offers superior RTO characteristics. Cloud recovery is governed by the Bank's Cloud Policy and subject to the same security, data sovereignty and regulatory requirements as on-premises infrastructure.

### 9.5.4 Database Recovery

Database recovery capabilities are as follows:

| Database System           | Replication Mode          | RPO         | Recovery Method      | Validation Frequency |
|---------------------------|---------------------------|-------------|----------------------|----------------------|
| Core Banking (Oracle RAC) | Synchronous Active-Active | < 1 minute  | Automatic failover   | Quarterly            |
| Payment Processing DB     | Synchronous Active-Active | < 5 minutes | Automatic failover   | Quarterly            |
| Regulatory Reporting DB   | Asynchronous log shipping | < 1 hour    | Manual switchover    | Semi-annual          |
| Document Management       | Asynchronous replication  | < 4 hours   | Restore from replica | Annual               |

| Database System          | Replication Mode      | RPO        | Recovery Method     | Validation Frequency |
|--------------------------|-----------------------|------------|---------------------|----------------------|
| Analytics Data Warehouse | Daily snapshot backup | < 24 hours | Restore from backup | Annual               |

### 9.5.5 Backup Strategy

The Bank's backup strategy follows the 3-2-1 principle: three copies of all data; on two different media types; with at least one copy maintained off-site. Full details of backup policy, including frequency, encryption, retention and testing requirements, are set out in Section 9.10.

### 9.5.6 Replication

Data replication between the PDC and SDC is performed using dedicated, encrypted replication links with sufficient bandwidth to sustain peak production workloads without impacting customer-facing performance. Replication health is monitored continuously by the IT Operations team, with automated alerting triggered when replication lag exceeds defined thresholds. Replication architecture is reviewed annually and updated following any material change to the Bank's data estate.

### 9.5.7 DR Testing

Disaster Recovery testing is conducted in accordance with the schedule set out in Section 9.11. The Bank requires annual full-failover testing for all Tier 1 systems, with results reported to the Board. The scope, methodology and evidence requirements for DR testing are defined in the DR Testing Standard, which is maintained by the Head of IT Operations and approved by the CRO.

### 9.5.8 Validation

Following each DR test or actual recovery event, a formal validation process is conducted to confirm that systems have been restored to a consistent, correct and secure state. Validation requirements include: data integrity checks; reconciliation of transaction logs; confirmation of RTO and RPO achievement; security posture verification; and sign-off by the relevant system owner and IT Operations lead.

## 9.6 Cyber Incident Response

The Bank maintains a Cyber Security Incident Response Plan ("CSIRP") that provides a structured, evidence-led approach to detecting, containing, eradicating and recovering from cyber security incidents. The CSIRP is maintained by the CISO and reviewed annually, or following any material cyber incident or change in the threat landscape. This section summarises the Bank's response posture for the principal cyber threat categories.

**REGULATORY NOTICE", "Cyber incidents meeting the materiality threshold defined in DORA Article 18 must be reported to the PRA and FCA within 4 hours of classification. The CISO maintains primary responsibility for regulatory notification. Failure to notify within required timeframes constitutes a regulatory breach and must be escalated to the CRO immediately.**

### 9.6.1 Malware

Upon detection of malware, the following immediate response actions are activated: endpoint isolation via automated EDR tooling; activation of the Cyber Incident Response Team ("CIRT"); preservation of forensic evidence; assessment of lateral movement and data exfiltration risk; and engagement of the Bank's retained cyber incident response retainer. Remediation follows a documented clean-build procedure with rigorous change management controls.

### 9.6.2 Ransomware

Ransomware events are treated as Category 1 Crisis events and immediately escalated to the CEO and CRO. The Bank's ransomware response plan incorporates: immediate network segmentation; activation of the Crisis Management Executive Committee; engagement of law enforcement (National Cyber Security Centre, National Crime Agency); assessment of backup availability and integrity; legal privilege considerations regarding external communications; and a formal decision framework governing payment consideration (noting that the Bank's policy position is not to pay ransoms absent extraordinary Board-approved circumstances).

### 9.6.3 Insider Threat

Insider threat incidents are managed through a co-ordinated response involving Cyber Security, Human Resources, Legal, Compliance and Physical Security. Immediate response actions include: revocation of logical access; evidence preservation; initiation of HR disciplinary or law enforcement processes as appropriate; and assessment of data exposure and regulatory notification requirements. All insider threat investigations are conducted under legal privilege where appropriate.

### 9.6.4 Data Breach

Data breaches are managed in accordance with the Bank's Data Breach Response Procedure, which satisfies the requirements of the UK General Data Protection Regulation and the Data Protection Act 2018. The Bank's Data Protection Officer must be notified within one hour of a potential personal data breach being identified. Notification to the Information Commissioner's Office must be made within 72 hours where the breach is likely to result in a risk to the rights and freedoms of natural persons. Customer notification requirements are assessed case-by-case with legal and regulatory input.

### 9.6.5 Account Compromise

---

Customer account compromise is managed through the Bank's Fraud and Account Takeover Response Procedure. Immediate actions include: account suspension and verification; initiation of fraud investigation; notification to payment systems where funds are at risk; and proactive customer communication. Systemic account compromise events are escalated to the CIRT and may trigger BCP activation if the volume of affected accounts exceeds defined thresholds.

### 9.6.6 Network Attack

---

Network-level attacks, including intrusion attempts and Advanced Persistent Threat ("APT") activity, are responded to by the Bank's Security Operations Centre ("SOC"), which operates on a 24/7/365 basis. The SOC maintains documented playbooks for all known network attack vectors and has authority to implement defensive measures including blocking, traffic re-routing and temporary service suspension to prevent further compromise.

### 9.6.7 Distributed Denial of Service (DDoS)

---

DDoS attacks are mitigated through the Bank's contracted DDoS scrubbing service, which provides automated traffic filtering capacity of up to [REDACTED] Gbps. In the event of a sustained DDoS attack exceeding filtering capacity, the Bank's internet banking contingency plan is activated, providing customers with alternative access channels. DDoS events are reported to the CIRT and escalated to the CRO where service availability falls below the Bank's impact tolerances.

### 9.6.8 Supply Chain Attack

---

Supply chain attacks targeting third-party software or service providers are managed through the Third Party Incident Response Protocol, which requires immediate quarantining of affected software, assessment of the Bank's exposure, engagement with the affected vendor, and where necessary activation of vendor contingency arrangements. The Bank participates in the Financial Services Information Sharing and Analysis Centre ("FS-ISAC") and NCSC threat intelligence sharing programmes to receive early warning of supply chain threats.

## 9.7 Crisis Management

The Bank's Crisis Management Framework provides a structured and scalable response capability to manage events that threaten the Bank's ability to deliver critical services, protect customer assets or maintain its regulatory standing. The framework operates across four classification levels, each with defined escalation, decision-making and communication requirements.

### 9.7.1 Incident Classification

| Level | Classification                    | Criteria                                                                                                                      | Initial Response Owner                      |
|-------|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|
| P1    | Category 1 – Crisis               | Threat to systemic stability, critical service failure >2hrs, regulatory notification required, reputational catastrophe risk | CEO / Crisis Management Executive Committee |
| P2    | Category 2 – Major Incident       | Significant disruption to important business services, potential regulatory impact, widespread customer impact                | CRO / Incident Management Team              |
| P3    | Category 3 – Significant Incident | Disruption to non-critical services, limited customer impact, managed within business unit                                    | Business Unit Head / BCM Manager            |
| P4    | Category 4 – Minor Incident       | Isolated disruption, no customer impact, resolved by IT or operations team                                                    | IT Operations / Service Desk                |

### 9.7.2 Crisis Levels and Escalation

Incidents are initially classified by the IT Service Desk or first responder and escalated in accordance with the Incident Escalation Matrix. Classification may be upgraded at any time as new information becomes available. Downgrade of classification requires the approval of the CRO for P2 events and the CEO for P1 events. Regulatory obligations, including incident notification requirements, apply from the point of initial classification and are not deferred pending resolution.

### 9.7.3 War Room Activation

The Crisis Management War Room is activated for all P1 and P2 events. The War Room is a physically dedicated facility equipped with independent communications, real-time dashboard displays, secure document handling and video conferencing capability. The War Room is staffed by the Crisis Management Executive Committee and supported by representatives from IT Operations, Cyber Security, Legal, Communications and Customer Operations. A virtual War Room capability is available for remote activation where physical access is not possible.

### 9.7.4 Executive Response



The Crisis Management Executive Committee ("CMEC") consists of the following members:

- Chief Executive Officer (Chair);
- Chief Risk Officer;
- Chief Financial Officer;
- Chief Information Officer;
- Chief Information Security Officer;
- Chief Operating Officer;
- General Counsel;
- Head of Communications & Investor Relations;
- Head of Customer Operations.

The CMEC convenes within 60 minutes of a P1 declaration and operates on a continuous basis until the crisis is resolved or downgraded. CMEC decisions are recorded by a designated Crisis Scribe and form part of the incident evidence record.

### **9.7.5 Decision Authority**

---

Decision authority during a crisis event is governed by the Crisis Management Decision Authority Matrix, which defines who may authorise specific actions including: emergency procurement; service suspension; regulatory notification; media statements; staff deployment; and liaison with law enforcement. The CEO has authority to override standard approval thresholds within the limits of the Board-approved Crisis Management Authority Delegation.

### **9.7.6 Media Response**

---

All media enquiries during a crisis event are handled exclusively by the Head of Communications & Investor Relations, in consultation with the CEO and General Counsel. No other employee is authorised to make statements to the media or post content on social media relating to a declared crisis event. The Bank maintains pre-approved holding statements for the principal crisis scenarios, which are reviewed annually and updated as part of crisis simulation exercises.

### **9.7.7 Customer Communication**

---

Customer communications during a crisis event are managed through the Customer Crisis Communication Protocol, which provides: initial acknowledgement within 1 hour of service disruption; status updates at intervals not exceeding 2 hours; clear information on alternative service channels; and personalised communication to high-value or vulnerable customers where appropriate. All customer communications are reviewed and approved by the Head of Communications and Legal before release.



## 9.8 Operational Resilience

This section sets out the Bank's approach to implementing the PRA and FCA's operational resilience framework, including the identification of Important Business Services (('IBS')), the setting of impact tolerances, service and dependency mapping, and the programme of resilience testing.

### 9.8.1 Critical Services & Important Business Services

The Bank has identified the following Important Business Services in accordance with the PRA and FCA operational resilience framework:

| IBS Reference | Important Business Service              | Customer Segment   | Regulatory Priority |
|---------------|-----------------------------------------|--------------------|---------------------|
| IBS-001       | Retail Payment Services                 | Retail             | High                |
| IBS-002       | Online and Mobile Banking Access        | Retail / SME       | High                |
| IBS-003       | Credit and Lending Services             | Retail / Corporate | High                |
| IBS-004       | Treasury and Financial Markets Services | Institutional      | High                |
| IBS-005       | Card Services                           | Retail / SME       | High                |
| IBS-006       | Trade Finance                           | Corporate          | Medium              |
| IBS-007       | Custody and Settlement                  | Institutional      | High                |
| IBS-008       | SME Banking Services                    | SME                | Medium              |

### 9.8.2 Service Mapping

For each Important Business Service, the Bank has produced a comprehensive Service Map that identifies: all processes and sub-processes that contribute to delivery of the IBS; technology systems and infrastructure components; data flows and interfaces; third-party and outsourced components; facilities and physical infrastructure; and staff and skills dependencies. Service Maps are reviewed and updated semi-annually and following any material change.

### 9.8.3 Dependency Mapping

The Bank maintains a Dependency Register for each IBS, identifying all internal and external dependencies, including: technology platform dependencies; payment scheme memberships (Bacs Payment Schemes, CHAPS, Visa, Mastercard); regulatory infrastructure dependencies (Bank of England RTGS, CREST); third-party SaaS and technology providers; utilities (power, telecommunications); and human capital dependencies. Single points of failure identified through dependency mapping are subject to formal risk treatment within the Risk Register.

### 9.8.4 Impact Tolerances

| IBS Reference                   | Impact Tolerance – Maximum Disruption Duration               | Notes                                     |
|---------------------------------|--------------------------------------------------------------|-------------------------------------------|
| IBS-001 – Retail Payments       | No customer unable to make/receive payment for > 2 hours     | Includes scheduled maintenance exclusions |
| IBS-002 – Online/Mobile Banking | No customer unable to access online banking for > 2 hours    | Measured excluding planned outages        |
| IBS-003 – Credit & Lending      | No lending decision or disbursement delayed > 4 hours        | Critical disbursements – 2 hours          |
| IBS-004 – Treasury Services     | No Treasury dealing function unavailable > 1 hour            | FX and money market dealing               |
| IBS-005 – Card Services         | No card authorisation failure rate > 0.5% for > 30 minutes   | —                                         |
| IBS-006 – Trade Finance         | No documentary credit process delayed > 8 hours              | —                                         |
| IBS-007 – Custody & Settlement  | No settlement failure attributable to Bank system > 24 hours | —                                         |
| IBS-008 – SME Banking           | No SME customer unable to access core banking > 4 hours      | —                                         |

### 9.8.5 Resilience Testing

The Bank conducts an annual programme of resilience testing for each IBS, designed to demonstrate the Bank's ability to remain within impact tolerances during severe but plausible disruption scenarios. Testing approaches include tabletop exercises, fire drills, parallel running, full failover tests and scenario-based simulations. The results of all resilience tests are documented, reviewed by the CRO and reported to the Board. Where tests reveal that impact tolerances cannot be maintained, a formal remediation plan must be approved within 30 days. Full testing methodology is set out in Section 9.11.

## 9.9 Third Party Resilience

The Bank's Third Party Resilience Framework ensures that the operational resilience obligations applicable to the Bank are effectively flowed down to, and maintained by, all third parties that provide material services. This framework operates in conjunction with the Bank's Third Party and Outsourcing Policy and aligns with PRA SS2/21 requirements.

### 9.9.1 Vendor Failures

In the event of a material vendor failure, the Bank activates the Vendor Failure Response Protocol, which encompasses: immediate assessment of service impact; activation of contractual remedies; engagement of contingency suppliers; Board notification where the vendor provides a service critical to an IBS; and regulatory notification where required. The Bank maintains pre-negotiated contingency agreements with alternative suppliers for all Tier 1 critical service providers.

### 9.9.2 Cloud Providers

Cloud service providers are subject to enhanced due diligence and contractual requirements, including: minimum uptime SLAs of 99.95% for services supporting Tier 1 processes; contractual right of access for Bank and regulatory audits; data residency commitments to UK-based processing and storage; exit assistance obligations of no less than 12 months; and incident notification requirements within 4 hours of a material outage. Cloud providers are assessed against the Bank's Cloud Security Standard and the NCSC Cloud Security Principles.

### 9.9.3 Critical Suppliers

The Bank maintains a Critical Supplier Register, which identifies all suppliers whose failure would cause the Bank to breach an IBS impact tolerance. Critical suppliers are subject to:

- Annual on-site or remote resilience due diligence assessment;
- Provision of independently audited BCP and DR documentation;
- Participation in the Bank's annual third-party resilience exercise;
- Quarterly service performance and resilience reporting;
- Financial health monitoring with defined thresholds for escalation.

### 9.9.4 Contractual Requirements

All contracts with material third-party service providers must include the following BCM and DR provisions as a minimum:

- Obligation to maintain a BCP and DRP meeting ISO 22301 standards or equivalent;
- RTO and RPO commitments aligned with or exceeding the Bank's own requirements;
- Annual BCP testing with results provided to the Bank within 30 days;
- Immediate notification of any actual or potential disruption to services within 2 hours;
- Right of the Bank to participate in third-party DR testing exercises;
- Step-in rights permitting the Bank to take over service delivery in an emergency;
- Exit assistance obligations for a period of not less than 12 months.

### 9.9.5 Exit Strategy

The Bank maintains a documented Exit Strategy for each critical supplier, updated annually, which sets out: the circumstances under which exit would be triggered; the sequence of exit activities; transition

timescales; alternative supplier options; cost estimates; customer communication requirements; and regulatory notification obligations. Exit Strategies are reviewed by the CRO and approved by the Risk & Compliance Committee.

### **9.9.6 Monitoring**

---

Ongoing monitoring of critical third-party resilience is performed through: quarterly resilience health checks; review of third-party incident reports; continuous financial health monitoring; participation in FS-ISAC threat intelligence sharing; and real-time service performance monitoring via integrated monitoring dashboards. Material deterioration in a critical supplier's resilience posture is escalated to the CRO and reported to the Risk & Compliance Committee.

## 9.10 Backup Policy

The Bank's Backup Policy establishes the minimum standards for data backup across all systems and data classifications. The policy is designed to ensure that data can be recovered to meet the RPOs defined in Section 9.3, and that backup integrity is maintained through regular testing and validation.

### 9.10.1 Backup Frequency

| Data Classification       | Backup Frequency                   | Backup Type             | Retention Period      |
|---------------------------|------------------------------------|-------------------------|-----------------------|
| Customer transaction data | Continuous (real-time replication) | Synchronous replication | 7 years               |
| Core banking data         | Every 15 minutes                   | Incremental snapshot    | 7 years               |
| Regulatory reporting data | Hourly                             | Incremental             | 7 years               |
| Email and communications  | Daily                              | Full daily backup       | 3 years               |
| Document management       | Daily                              | Full daily backup       | Varies by record type |
| Analytics and reporting   | Daily                              | Full daily backup       | 3 years               |
| Configuration data        | On-change + weekly full            | Full + incremental      | 5 years               |
| Endpoint data             | Daily                              | Incremental             | 90 days               |

### 9.10.2 Encryption

All backups, whether stored on-premises, at the secondary data centre or in cloud storage, must be encrypted using AES-256 encryption. Encryption keys are managed in accordance with the Bank's Key Management Policy and are stored separately from the encrypted backup data. Key escrow arrangements are maintained to ensure data accessibility in the event of key custodian unavailability.

### 9.10.3 Retention

Backup retention periods are determined by reference to: regulatory obligations under DORA, PRA rules and applicable data protection legislation; the Bank's Records Management Policy; legal hold requirements; and operational recovery requirements. Retention periods are reviewed annually by the Data Governance Committee and updated to reflect any changes in regulatory requirements. Data destruction at the end of retention periods must be performed using approved secure deletion methods and documented in the Records Destruction Register.

### 9.10.4 Off-site Storage

Physical backup media (where used) must be stored at approved off-site facilities maintaining a minimum of 50 kilometres distance from the production data centre. Off-site storage facilities must meet the Bank's physical security standards and be subject to annual security assessment. Inventory and media management procedures are documented in the Backup Media Management Standard.

### 9.10.5 Cloud Storage

Cloud backup storage must be configured to satisfy all requirements of the Bank's Cloud Policy and Data Sovereignty Policy. All cloud-stored backups must remain within UK data centre regions unless explicit regulatory permission has been obtained. Cloud storage providers are subject to the same due diligence and contractual requirements as cloud service providers described in Section 9.9.2.

### 9.10.6 Backup Testing

---

Backup integrity is validated through the following testing schedule:

- Random spot-restore testing: minimum 10% of backup sets per month, covering all systems on a rolling basis;
- Full system restore test: at least annually for all Tier 1 and Tier 2 systems;
- Database consistency checks: automated, executed daily as part of backup completion verification;
- Encryption verification: quarterly confirmation that backup encryption is functioning correctly;
- Off-site retrieval test: semi-annual test of physical media retrieval and restore from off-site storage.

### 9.10.7 Restoration

---

Restoration procedures are documented in system-specific DR Runbooks maintained by the Head of IT Operations. All Runbooks must be reviewed and validated as part of the annual DR testing cycle. Restoration procedures must specify: the sequence of restoration steps; estimated restoration time; data validation steps; sign-off requirements; and escalation contacts in the event of restoration failure. Restoration of production systems from backup requires dual authorisation by the Head of IT Operations and the relevant system owner.

## 9.11 Disaster Recovery Testing

Disaster Recovery testing is a mandatory, scheduled programme of exercises designed to validate the Bank's technical and operational recovery capabilities against documented RTOs and RPOs. The DR testing programme is approved annually by the CRO, with a summary of testing results reported to the Board Risk & Compliance Committee.

### 9.11.1 Tabletop Exercises

Tabletop exercises are facilitated scenario discussions in which key personnel walk through their response to a hypothetical disruption event. Tabletop exercises are conducted at least twice per year for Tier 1 processes and at least annually for all other critical processes. Exercises are facilitated by the BCM Manager and attended by business unit heads, IT Operations, Cyber Security and relevant third-party representatives. Outputs include: a list of identified gaps; agreed remediation actions; and a lessons-learned report distributed to the CRO within 10 business days.

### 9.11.2 Simulation Exercises

Simulation exercises replicate the conditions of a disruption event without executing actual system failover. They test communication protocols, decision-making processes, manual procedures and inter-team coordination. Simulations are conducted at least annually and must include representatives from all business units with Tier 1 or Tier 2 process responsibilities. Simulations may be conducted with or without prior notification to participants. Unannounced simulations must be approved by the CRO and communicated to the Board in advance.

### 9.11.3 Full Failover Testing

Full failover testing involves the actual transfer of live or representative workloads from the PDC to the SDC or cloud recovery environment. Full failover tests are conducted at least annually for all Tier 1 systems and are scheduled during approved maintenance windows to minimise customer impact. Pre-test requirements include: Board notification; regulator notification where required; customer communication where service impact is anticipated; rollback plan review and approval; and pre-test backup verification.

### 9.11.4 Recovery Testing

Recovery testing validates the Bank's ability to restore individual systems, applications and data from backup within the specified RPO. Recovery tests are conducted on a rolling basis throughout the year, ensuring each system is tested at least annually. Recovery test results are recorded in the DR Test Log maintained by IT Operations and reviewed by the BCM Manager. Any system failing to meet its RPO during recovery testing must be subject to a root cause analysis and formal remediation plan within 30 days.

### 9.11.5 Lessons Learned

Following each DR test or exercise, a formal Lessons Learned Review is conducted within 15 business days. The review identifies: what worked well; what failed or was insufficient; root causes of failures; and recommendations for improvement. All recommendations are documented as action items with named owners and target completion dates. Material findings are escalated to the CRO and reported to the Risk & Compliance Committee. Completed actions are tracked in the BCM Action Register and evidenced through re-testing where appropriate.

### 9.11.6 Evidence Requirements

The following evidence must be captured and retained for each DR test or exercise:

- Pre-test checklist completed and signed off;
- Attendee register (for tabletop and simulation exercises);
- Screen captures or log extracts evidencing failover or recovery completion;
- Timestamps demonstrating RTO and RPO achievement;
- Data integrity validation outputs;
- Post-test debrief notes;
- Signed test completion certificate from the Head of IT Operations and BCM Manager.

All evidence is retained for a minimum of five years and is available for regulatory inspection upon request.

### 9.11.7 Reporting

DR test results are reported through the following governance channels:

| Report                            | Recipient                         | Frequency           | Format                            |
|-----------------------------------|-----------------------------------|---------------------|-----------------------------------|
| DR Test Summary Report            | CRO                               | Following each test | Written report with evidence pack |
| Annual DR Testing Report          | Board Risk & Compliance Committee | Annually            | Board paper                       |
| Regulatory Self-Assessment Update | PRA / FCA (if material change)    | As required         | Regulatory submission             |
| Third-Party Test Results          | CRO / Risk Committee              | Quarterly           | Summary table                     |



## 9.12 Emergency Communications

Effective and timely communications are a critical component of the Bank's crisis and incident response capability. The Emergency Communications Framework defines the protocols, channels, approval processes and responsibilities for all communications during a declared incident or crisis.

### 9.12.1 Employee Communications

Internal communications during an incident are managed through:

- The Bank's Mass Notification System ("MNS"), which enables simultaneous broadcast to all employees via SMS, email and phone within 15 minutes of activation;
- All-staff email updates from the CEO or CRO for Category 1 and 2 events;
- Departmental cascade communications via line managers for operational instructions;
- Regular situational briefings, at intervals not exceeding 4 hours during active incidents, distributed via the Bank's internal communications platform.

### 9.12.2 Customer Communications

Customer communications are managed in accordance with the Customer Crisis Communication Protocol described in Section 9.7.7. All customer-facing communications must be approved by the Head of Communications and Legal prior to release. The Bank's website, mobile app and telephone banking IVR system are used to distribute service status updates. Vulnerable customers and those with accessibility needs are prioritised in communication planning.

### 9.12.3 Regulatory Notifications

Regulatory notifications are the responsibility of the CRO, assisted by the General Counsel and Compliance function. Notification timescales are:

| Regulatory Body                         | Notification Trigger                                      | Timescale                                                   | Method                                               |
|-----------------------------------------|-----------------------------------------------------------|-------------------------------------------------------------|------------------------------------------------------|
| Prudential Regulation Authority (PRA)   | Material operational incident, breach of impact tolerance | As soon as practicable; initial notification within 4 hours | Supervisory contact then formal written notification |
| Financial Conduct Authority (FCA)       | Material operational incident, consumer harm              | As soon as practicable; initial notification within 4 hours | Supervisory contact then formal written notification |
| Information Commissioner's Office (ICO) | Personal data breach (high risk to individuals)           | Within 72 hours of becoming aware                           | ICO online reporting system                          |
| Bank of England                         | Payment system disruption, systemic risk                  | Immediate notification, no later than 1 hour                | Direct supervisory contact                           |
| National Crime Agency (NCA)             | Financial crime, fraud, cybercrime                        | Within 24 hours of confirmed criminality                    | Suspicious Activity Report or direct contact         |
| NCSC                                    | Significant cyber incident                                | As soon as practicable                                      | NCSC online reporting; phone for Category 1          |

### 9.12.4 Media Response

Media enquiries received during an incident are directed exclusively to the Head of Communications. Social media monitoring is conducted continuously during active incidents by the Communications team. The Bank does not issue media statements without sign-off from the CEO and General Counsel. Pre-approved holding statements are maintained for the principal incident scenarios and are available for immediate deployment.

### **9.12.5 Board Communications**

---

The Board is notified of all P1 and P2 incidents within 2 hours of declaration. Board notification is the responsibility of the CEO, assisted by the Company Secretary. Board members are briefed at intervals not exceeding 6 hours during active P1 crises. A formal Board paper documenting the incident, response and lessons learned is presented at the next scheduled Board meeting following incident closure.

### **9.12.6 Emergency Contacts**

---

The Bank maintains an Emergency Contact Directory, updated quarterly, containing contact details for all critical internal and external contacts required during an incident. The Directory is accessible from the DR site, the War Room and via the encrypted mobile BCP application issued to all CMEC members. The Directory includes contacts for: all CMEC members; IT Operations and CIRT team; regulatory supervisors; payment scheme operators; key third-party suppliers; law enforcement; and crisis communications advisors.

### **9.12.7 Notification Matrix**

---

The Notification Matrix sets out who must be notified of each incident classification, by whom and within what timescale. The matrix is reviewed annually and approved by the CRO. Notification obligations escalate automatically as incident classification is upgraded. Failure to notify in accordance with the matrix is treated as a compliance breach and must be reported to the CRO.

## 9.13 Pandemic Response

The Bank's Pandemic Response Plan ("PRP") has been developed to ensure continuity of critical banking services during a pandemic or other large-scale public health emergency. The PRP reflects lessons learned from the COVID-19 pandemic and has been updated to align with guidance from HM Government, Public Health England and the Bank of England's operational resilience expectations.

### 9.13.1 Remote Operations

The Bank has established a permanent remote operations capability that enables 100% of eligible staff to work from home simultaneously without degradation to Tier 1 service levels. Remote operations infrastructure includes: enterprise VPN with capacity for all concurrent users; cloud-hosted collaboration and communication tools; secure remote access to all critical systems; and virtual War Room capability for crisis management. Remote operations capacity is tested quarterly.

### 9.13.2 Health Measures

During a declared public health emergency, the Bank activates its Health & Safety Pandemic Protocol, which includes:

- Enhanced cleaning and hygiene measures at all operational sites;
- Provision of personal protective equipment to all staff required to attend site;
- Temperature screening and health declaration procedures at all Bank premises;
- Social distancing and workplace density management controls;
- Prohibition on non-essential travel;
- Regular health and wellbeing communications to all staff.

### 9.13.3 Essential Staff

The Bank maintains a Critical Presence List ("CPL") identifying staff whose physical presence is required at Bank premises to maintain Tier 1 services that cannot be delivered remotely. CPL staff are supported with:

- Guaranteed transportation to and from operational sites;
- Priority access to personal protective equipment;
- Enhanced wellbeing support and regular welfare checks;
- Financial recognition consistent with the Bank's pandemic response HR policy.

### 9.13.4 Cross-Training

The Bank's cross-training programme ensures that no critical function depends on the availability of a single individual or team. Cross-training requirements for pandemic preparedness include: minimum two trained operatives for each critical role; documented knowledge transfer processes; annual competency assessments; and cross-departmental secondment arrangements for key skills. Cross-training records are maintained in the HR system and reviewed by the BCM Manager.

### 9.13.5 Operational Continuity

Operational continuity during a pandemic is supported by the following additional measures:

- Extended operating hours for critical functions where staffing allows;
- Priority access to IT support for remote workers on critical processes;

- Suspension of non-critical change activity during the declared pandemic period;
- Enhanced monitoring of all Tier 1 process SLAs with daily reporting to the CRO;
- Regular review of the PRP by the CMEC at intervals not exceeding weekly during an active pandemic event.

## 9.14 Physical Security Events

The Bank's Physical Security Event Response Framework provides structured response procedures for physical threats to Bank premises, staff and equipment. Response plans are maintained in coordination with local emergency services, building management and the Bank's physical security provider.

### 9.14.1 Fire

Fire response is governed by the Bank's Fire Emergency Procedure, which is reviewed annually and tested through quarterly fire drills. Key provisions include: automatic fire detection and suppression systems at all data centre and operational sites; designated fire wardens for all operational floors; evacuation procedures and assembly points; coordination with local fire and rescue services; and a data centre fire suppression system designed to minimise water damage to IT equipment.

### 9.14.2 Flood

Flood risk has been assessed for all Bank premises. Premises identified as being in a flood risk area are subject to enhanced flood preparedness measures including: raised IT equipment and server racks; water barriers and flood protection equipment; elevated electrical infrastructure; and documented evacuation procedures with transport provisions. The primary and secondary data centres are located in sites assessed as having negligible flood risk.

### 9.14.3 Earthquake

Although the UK presents low seismic risk, the Bank's international offices in seismically active regions are subject to earthquake preparedness requirements including: seismically rated building certification; documented 'drop, cover and hold' procedures; post-event structural assessment protocols before reoccupation; and emergency supply caches sufficient for 72 hours of operations.

### 9.14.4 Civil Unrest

In the event of civil unrest affecting Bank premises, the following measures are activated: assessment of operational risk by the Physical Security Manager; potential closure of affected branches in coordination with the Head of Retail Operations; remote working activation for affected staff; enhanced physical security measures including security personnel deployment; and liaison with local police services.

### 9.14.5 Terrorism and Bomb Threat

The Bank's Counter-Terrorism and Security Act 2015 obligations are managed through the Bank's Security Plan, which is reviewed annually and shared with the National Counter Terrorism Security Office ("NaCTSO") upon request. All staff complete mandatory Counter-Terrorism Awareness training, including recognition of suspicious packages and behaviours. Bomb threat response procedures are documented in the Physical Security Response Manual and tested annually.

### 9.14.6 Building Access

Physical access to Bank premises is controlled through a layered access control system including: biometric and card-based access controls; CCTV coverage of all public and staff access areas; visitor management procedures; and tailgating prevention measures. Emergency access procedures, including master overrides and failsafe unlock protocols for emergency evacuation, are documented in the Physical Security Operations Manual.

### 9.14.7 Evacuation

---

Evacuation procedures are maintained for all Bank premises and reviewed annually. Procedures include: designated evacuation routes with posted floor plans; named fire wardens and deputy wardens for each floor; assembly point locations communicated to all staff; roll-call and accountability procedures; provision for staff with mobility impairments; and post-evacuation communication protocols. Full evacuation drills are conducted at least annually at all major operational sites.

## 9.15 Incident Reporting

The Bank's incident reporting framework ensures that all operational disruptions, near misses and significant events are captured, assessed, escalated and addressed in a timely and consistent manner. Effective incident reporting supports the Bank's continuous improvement obligations and provides the evidence base required for regulatory self-assessment and audit review.

### 9.15.1 Incident Classification

All incidents are classified at the point of initial identification using the four-tier classification model defined in Section 9.7.1. Classification is performed by the first responder and confirmed by the IT Service Desk within 30 minutes. Incident classification may be escalated at any time as the severity or impact of the event becomes clearer.

### 9.15.2 Major Incidents

A major incident is defined as any P1 or P2 event causing or likely to cause material disruption to one or more Important Business Services, with potential regulatory notification obligations. Major incidents require:

- Immediate escalation to the CRO and CEO;
- Activation of the Incident Management Team within 30 minutes;
- Regulatory assessment and notification decision within 4 hours;
- Board notification within 2 hours of P1 classification;
- Completion of a Major Incident Report within 5 business days of closure.

### 9.15.3 Minor Incidents

Minor incidents (P3 and P4) are managed by the relevant business unit or IT Operations team and reported to the BCM Manager via the incident management system within 24 hours. Minor incidents that recur three or more times within a 90-day period are automatically escalated for root cause analysis. Trends in minor incident data are reviewed monthly by the BCM Manager.

### 9.15.4 Near Miss Reporting

Near misses – events that had the potential to cause disruption but did not – are reported through the same channels as actual incidents and treated with equal analytical rigour. A positive near miss reporting culture is promoted by the Bank's management, and staff are encouraged to report near misses without fear of sanction. Near miss data is analysed quarterly by the BCM Manager and integrated into the risk assessment process.

### 9.15.5 Root Cause Analysis

Root cause analysis ("RCA") is mandatory for all P1 and P2 incidents and for any P3 incident meeting the recurrence threshold defined above. RCA must be completed within 15 business days of incident closure using a recognised methodology (5 Whys, Fishbone/Ishikawa or Fault Tree Analysis). RCA outputs are reviewed by the CRO and documented in the Incident Register. Where the RCA identifies systemic weaknesses, findings are escalated to the relevant risk owner for formal risk treatment.

### 9.15.6 Lessons Learned

A formal Lessons Learned Review is conducted following all P1 and P2 incidents and at least annually for the aggregate portfolio of P3 incidents. Lessons learned are documented in the BCM Lessons Learned Register and systematically integrated into relevant BCPs, DRPs, training materials and risk assessments. The Lessons Learned Register is presented to the Risk & Compliance Committee quarterly.

### **9.15.7 Corrective Actions**

---

All corrective actions arising from incident reviews are documented in the BCM Action Register with a named owner and agreed completion date. Corrective actions arising from P1 incidents must be completed within 30 calendar days unless a risk-accepted extension has been approved by the CRO. Progress against all open actions is reviewed monthly by the BCM Manager and reported quarterly to the Risk & Compliance Committee. Overdue actions are escalated to the CRO.



## 9.16 Post-Incident Review

The Post-Incident Review ("PIR") process provides a structured, multi-perspective assessment of significant operational incidents, with the objective of identifying root causes, evaluating the effectiveness of the Bank's response and implementing sustainable improvements. The PIR process applies to all P1 and P2 incidents and selected P3 incidents at the BCM Manager's discretion.

### 9.16.1 Recovery Review

The Recovery Review assesses the technical and operational aspects of the Bank's incident response, including: the accuracy and completeness of initial incident detection and classification; the effectiveness of recovery procedures; adherence to RTOs and RPOs; the adequacy of communication during the recovery period; and the quality of evidence captured. The Recovery Review is led by the BCM Manager and completed within 10 business days of incident closure.

### 9.16.2 Management Review

The Management Review assesses the adequacy of governance, decision-making and escalation during the incident. It considers: whether the appropriate crisis level was declared promptly; the effectiveness of the CMEC and War Room operations; the quality and timeliness of communications to stakeholders; and whether the Bank's decision-making processes performed as designed. The Management Review is led by the CRO and completed within 15 business days.

### 9.16.3 Internal Audit Review

For all P1 incidents and any P2 incident with regulatory notification implications, the Internal Audit function conducts an independent Post-Incident Audit Review. This review assesses: whether the Bank's policies and procedures were followed; the adequacy of the evidence trail; whether regulatory obligations were met; and the completeness of the corrective action plan. The Internal Audit Review is completed within 30 business days and reported to the Audit Committee.

### 9.16.4 Risk Review

Following each PIR, the Risk Management function updates the Bank's risk register to reflect: any new risks identified; changes to residual risk ratings for existing risks; new or revised controls required; and updated risk appetite calibration where appropriate. Risk review outputs are presented to the Risk & Compliance Committee at the next scheduled meeting.

### 9.16.5 Policy Improvements

Lessons learned and recommendations arising from the PIR process are systematically evaluated against all relevant policies, procedures and standards. Policy improvements identified through the PIR process are implemented through the Bank's policy management framework and are subject to the same review and approval process as planned policy updates. The BCM Manager maintains a log of all policy changes arising from PIR recommendations.

## 9.17 Training & Exercises

The Bank's BCM training and exercise programme ensures that all staff with BCM responsibilities maintain the awareness, knowledge and practical capability to execute their roles effectively during a disruptive event. The programme is designed in accordance with ISO 22301:2019 Clause 8.5 and is reviewed annually by the BCM Manager.

### 9.17.1 Annual Testing Programme

The annual testing programme is approved by the CRO each January and encompasses: tabletop exercises; departmental BCM drills; executive crisis simulations; cyber incident simulations; full DR failover tests; backup restoration tests; and third-party resilience assessments. The programme is designed to ensure comprehensive coverage of all Tier 1 and Tier 2 processes within each calendar year.

### 9.17.2 Department Drills

Each business unit is required to conduct at least two BCM drills per year: one announced drill to test planned procedures, and one unannounced drill to test genuine response capability. Drills must be documented, with attendance records, observations and action items recorded in the BCM Exercise Log. Drill results are reported to the BCM Manager within 5 business days.

### 9.17.3 Executive Crisis Simulations

An executive-level crisis simulation is conducted at least annually, involving all CMEC members. The simulation is designed and facilitated by the BCM Manager, with independent observation and feedback from an external specialist. Executive simulations test: crisis classification and escalation; War Room operations; regulatory notification decisions; media response; and Board communication. A facilitated debrief and written feedback report are provided to the CEO and CRO within 10 business days.

### 9.17.4 Cyber Security Simulations

Cyber security simulations are conducted at least annually in coordination between the BCM Manager and CISO. Simulations include: ransomware response tabletop; phishing campaign awareness tests; DDoS response simulation; and insider threat response exercise. Cyber simulation results are reviewed by the CISO and reported to the Board Risk & Compliance Committee. The Bank engages external cyber simulation specialists at least every two years to provide independent challenge.

### 9.17.5 Recovery Drills

Recovery drills test the Bank's ability to relocate critical operations to alternative sites or activate remote working arrangements within the RTO for affected processes. Recovery drills are conducted at each designated alternative location at least annually and include: activation of alternative site IT infrastructure; testing of communications links; staff access and credential validation; and processing of representative transaction volumes.

### 9.17.6 Staff Awareness

All employees are required to complete mandatory BCM awareness training upon joining the Bank and annually thereafter. The training programme covers: the Bank's BCM policy; staff responsibilities during a disruptive event; emergency communication channels; evacuation procedures; and reporting

obligations. Completion of mandatory BCM training is tracked by the HR system, and non-completion is reported to the BCM Manager for follow-up.

## 9.18 Framework Maintenance

This Framework is a living document that must be maintained in current, accurate and approved condition at all times. The maintenance requirements set out in this section ensure that the Framework remains aligned with the Bank's operational model, regulatory obligations and best practice standards.

### 9.18.1 Annual Review

This Framework is subject to a full, structured review at least annually, to be completed by 30 November each year to enable Board approval before year-end. The annual review encompasses: assessment against current regulatory requirements; benchmarking against industry best practice; integration of lessons learned from incidents and exercises; stakeholder input from business units, IT Operations and Cyber Security; and independent challenge from the Internal Audit function.

### 9.18.2 Version Control

Version control for this Framework is managed in accordance with the Bank's Document Management Policy. The version numbering convention is: Major version increments (e.g. 5.0 to 6.0) for material structural or policy changes; minor version increments (e.g. 5.4 to 5.5) for significant content updates; and patch-level increments (e.g. 5.4.0 to 5.4.1) for editorial corrections. All versions are stored in the Bank's document management system with a complete change history.

### 9.18.3 Regulatory Updates

The BCM Manager monitors regulatory developments relevant to this Framework on a continuous basis, including publications from the PRA, FCA, EBA, DORA implementing technical standards and ISO. Material regulatory changes that require amendments to this Framework are assessed by the CRO and approved through the expedited policy amendment process, which may bypass the annual review cycle where the regulatory change requires immediate implementation.

### 9.18.4 Policy Approval

Amendments to this Framework require approval as follows:

| Amendment Type                                       | Approver                                             | Timescale                    |
|------------------------------------------------------|------------------------------------------------------|------------------------------|
| Major version (structural or material policy change) | Board of Directors                                   | Before implementation        |
| Minor version (significant content update)           | Board Risk & Compliance Committee                    | Before implementation        |
| Patch-level (editorial or minor factual correction)  | Chief Risk Officer                                   | Within 5 business days       |
| Regulatory-driven emergency amendment                | Chief Risk Officer; Board notification within 5 days | Prior to regulatory deadline |

### 9.18.5 Continuous Improvement

The Bank commits to continuous improvement of its BCM and DR capabilities through: systematic integration of lessons learned; benchmarking against peer institutions and industry best practice; engagement with regulatory guidance and good practice publications; investment in BCM technology and

automation; participation in industry resilience forums; and independent external review at least every three years.

# Operational Resilience Statement

*Stratum Capital Bank commits to maintaining the operational resilience of its Important Business Services at all times. The Bank will invest, plan, test and continuously improve its capabilities to ensure it can remain within defined impact tolerances even during severe but plausible disruption scenarios. This commitment is endorsed by the Board of Directors and is fundamental to the Bank's duty to its customers, shareholders and the broader financial system.*

The Board of Directors of Stratum Capital Bank has reviewed and endorses this Operational Resilience Statement. The Board confirms that it has satisfied itself, through review of the annual resilience self-assessment, that the Bank has the capabilities necessary to meet its impact tolerances. The Board will continue to scrutinise operational resilience as a standing agenda item and will hold the Chief Risk Officer personally accountable for the ongoing adequacy of this Framework.

# Policy Supremacy Statement

This Chapter 9 of the Enterprise Governance & Risk Framework supersedes all previous versions of the Bank's Business Continuity Policy, Disaster Recovery Policy and Crisis Management Policy. In the event of any conflict or inconsistency between this Chapter and any other Bank policy, procedure or standard on matters of business continuity, disaster recovery or crisis management, the provisions of this Chapter shall prevail unless a specific written exemption has been granted by the Chief Risk Officer.

Where this Chapter conflicts with any applicable regulatory rule, statute or binding supervisory expectation, the regulatory obligation shall prevail, and the BCM Manager must notify the CRO immediately of any such conflict for resolution.

# Cross References to Chapters 1–8

| Chapter   | Title                                     | Relevant Cross-Reference                                                                                                                      |
|-----------|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| Chapter 1 | Enterprise Governance Framework           | Board accountability structures; Senior Management Functions; governance hierarchy referenced in Section 9.2                                  |
| Chapter 2 | Risk Appetite & Risk Management Framework | Risk appetite statements that inform impact tolerance calibration; risk treatment requirements for BCM-related risks in Sections 9.3 and 9.15 |
| Chapter 3 | Operational Risk Framework                | Operational risk event classification; loss data collection; scenario analysis methodology consistent with Section 9.3 BIA                    |
| Chapter 4 | Technology & Cyber Risk Policy            | Cyber risk management framework; CISO responsibilities; cyber incident                                                                        |

| Chapter   | Title                               | Relevant Cross-Reference                                                                                                          |
|-----------|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
|           |                                     | classification consistent with Section 9.6                                                                                        |
| Chapter 5 | Third Party & Outsourcing Policy    | Critical supplier management; due diligence; contractual requirements consistent with Section 9.9                                 |
| Chapter 6 | Data Governance & Protection Policy | Data classification; backup and retention requirements consistent with Section 9.10; GDPR obligations referenced in Section 9.6.4 |
| Chapter 7 | Compliance & Regulatory Framework   | Regulatory notification obligations; SM&CR responsibilities; regulatory relationship management consistent with Section 9.12.3    |
| Chapter 8 | Internal Controls & Audit Framework | Internal audit independence; post-incident audit review consistent with Section 9.16.3; control testing requirements              |

## Definitions

| Term                                         | Definition                                                                                                                                                                                                                          |
|----------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Active-Active Configuration                  | A DR architecture in which two or more sites simultaneously process live workloads, enabling immediate failover without data loss.                                                                                                  |
| Business Continuity Management (BCM)         | A holistic management process that identifies potential threats to an organisation and provides a framework for building resilience with the capability of an effective response that safeguards the interests of key stakeholders. |
| Business Continuity Plan (BCP)               | A documented collection of procedures and information developed, compiled and maintained in readiness for use in an incident to enable the Bank to continue to deliver its critical activities at an acceptable predefined level.   |
| Business Impact Analysis (BIA)               | An analytical process for determining and documenting the potential effects of disruption to business operations and the resources needed to recover.                                                                               |
| Crisis Management Executive Committee (CMEC) | The senior executive body convened to manage Category 1 and 2 crisis events, chaired by the CEO.                                                                                                                                    |
| Critical Supplier                            | A third-party supplier whose failure would cause the Bank to breach one or more IBS impact tolerances.                                                                                                                              |
| Disaster Recovery (DR)                       | The process, policies and procedures related to preparing for recovery or continuation of technology infrastructure, systems and applications after a natural or human-induced disaster.                                            |
| Disaster Recovery Plan (DRP)                 | Documented procedures for the recovery of IT systems, applications and data following a disruptive event.                                                                                                                           |
| Important Business Service (IBS)             | A service provided by the Bank to external customers whose disruption could cause harm to customers or market integrity, or pose risks to the safety and soundness of the Bank or financial system stability.                       |
| Impact Tolerance                             | The maximum tolerable disruption to an Important Business Service, set by the Board, beyond which the Bank would consider that harm is being caused to customers or markets.                                                        |
| Maximum Tolerable Downtime (MTD)             | The maximum time a business process can be disrupted before unacceptable consequences occur.                                                                                                                                        |
| Recovery Point Objective (RPO)               | The maximum acceptable amount of data loss measured in time, prior to a disruption event, that a business process can tolerate.                                                                                                     |



| Term                          | Definition                                                                                                                                                                                                           |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Recovery Time Objective (RTO) | The maximum acceptable time to restore a business process or system following a disruption.                                                                                                                          |
| Severe but Plausible Scenario | A scenario that is sufficiently extreme to test the limits of the Bank's resilience but plausible enough to have a reasonable probability of occurring. Used for resilience testing and impact tolerance validation. |
| War Room                      | The dedicated physical or virtual facility activated to coordinate the Bank's response to a declared crisis event.                                                                                                   |

## Appendix References

The following appendices form part of this Chapter and are maintained as controlled documents under separate cover in the BCM Document Library:

| Appendix Reference | Title                                           | Owner                              | Review Frequency   |
|--------------------|-------------------------------------------------|------------------------------------|--------------------|
| Appendix 9-A       | Business Continuity Policy Statement            | Chief Risk Officer                 | Annual             |
| Appendix 9-B       | Critical Process Register & BIA Results         | BCM Manager                        | Annual             |
| Appendix 9-C       | Business Continuity Plans – Master Index        | BCM Manager                        | Annual / On Change |
| Appendix 9-D       | Disaster Recovery Plans – Master Index          | Head of IT Operations              | Annual / On Change |
| Appendix 9-E       | IT Disaster Recovery Architecture Specification | Head of IT Operations              | Annual             |
| Appendix 9-F       | Cyber Security Incident Response Plan (CSIRP)   | Chief Information Security Officer | Annual             |
| Appendix 9-G       | Crisis Management Playbooks                     | BCM Manager                        | Annual             |
| Appendix 9-H       | Emergency Contact Directory                     | BCM Manager                        | Quarterly          |
| Appendix 9-I       | Notification Matrix                             | BCM Manager / Compliance           | Annual             |
| Appendix 9-J       | Third Party Resilience Due Diligence Template   | CRO / Vendor Management            | Annual             |
| Appendix 9-K       | Backup Policy & Retention Schedule              | Head of IT Operations              | Annual             |
| Appendix 9-L       | DR Test Plans & Evidence Log                    | Head of IT Operations              | Per Test Cycle     |
| Appendix 9-M       | BCM Training Programme & Completion Records     | BCM Manager / HR                   | Annual             |
| Appendix 9-N       | BCM Action Register                             | BCM Manager                        | Ongoing            |
| Appendix 9-O       | Operational Resilience Self-Assessment          | Chief Risk Officer                 | Annual             |
| Appendix 9-P       | Pandemic Response Plan                          | BCM Manager                        | Annual             |
| Appendix 9-Q       | Physical Security Response Manual               | Head of Physical Security          | Annual             |

| Appendix Reference | Title                                                   | Owner       | Review Frequency |
|--------------------|---------------------------------------------------------|-------------|------------------|
| Appendix 9-R       | Important Business Services – Service & Dependency Maps | BCM Manager | Semi-Annual      |

# Document Control

## Version History

| Version | Date         | Author            | Changes                                                                                                                                                                                                    | Approved By                       |
|---------|--------------|-------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|
| 5.4.1   | January 2025 | BCM Manager / CRO | Incorporation of DORA Article 11–14 requirements; updated impact tolerances for IBS-001 and IBS-002; enhanced supply chain attack response (9.6.8); third-party exit strategy requirements updated (9.9.5) | Board Risk & Compliance Committee |
| 5.4.0   | July 2024    | BCM Manager       | Mid-year update: updated regulatory notification timescales following FCA PS23/3; enhanced ransomware response section (9.6.2); cloud recovery enhancements (9.5.3)                                        | Chief Risk Officer                |
| 5.3.0   | January 2024 | BCM Manager / CRO | Annual review: updated RTO/RPO table (9.3.3); new pandemic response enhancements (9.13); executive simulation requirements updated (9.17.3)                                                                | Board Risk & Compliance Committee |
| 5.2.0   | January 2023 | BCM Manager       | Annual review: incorporated PRA SS1/21 self-assessment requirements; added operational resilience IBS register (9.8); updated third-party                                                                  | Board Risk & Compliance Committee |

| Version | Date         | Author                  | Changes                                                                                                           | Approved By        |
|---------|--------------|-------------------------|-------------------------------------------------------------------------------------------------------------------|--------------------|
|         |              |                         | requirements (9.9)                                                                                                |                    |
| 5.1.0   | June 2022    | BCM Manager             | Post-pandemic review: enhanced remote working section (9.4.4); updated pandemic response plan (9.13)              | Chief Risk Officer |
| 5.0.0   | January 2022 | CRO / External Advisors | Major revision: full structural rewrite aligning with ISO 22301:2019 and PRA/FCA operational resilience framework | Board of Directors |

## Review and Approval

|                              |                                                                                                    |
|------------------------------|----------------------------------------------------------------------------------------------------|
| <b>Document Owner</b>        | Chief Risk Officer, Stratum Capital Bank                                                           |
| <b>Policy Sponsor</b>        | Chief Executive Officer                                                                            |
| <b>Primary Author</b>        | Business Continuity Manager                                                                        |
| <b>Contributing Authors</b>  | Head of IT Operations; Chief Information Security Officer; General Counsel; Head of Communications |
| <b>Internal Reviewer</b>     | Internal Audit (Independent Assurance)                                                             |
| <b>External Reviewer</b>     | External BCM Specialist (biennial)                                                                 |
| <b>Approval Authority</b>    | Board Risk & Compliance Committee (minor/major); Board of Directors (major revision)               |
| <b>Next Scheduled Review</b> | 31 December 2025                                                                                   |

### DOCUMENT CONTROL NOTICE

This document is classified CONFIDENTIAL – INTERNAL USE ONLY. It must not be distributed outside of Stratum Capital Bank without the written approval of the Chief Risk Officer. Recipients are personally responsible for maintaining the confidentiality of this document and must not retain personal copies beyond the period required for their business purpose. Printed copies of this document are uncontrolled. Always refer to the Document Management System for the current approved version.

— END OF CHAPTER 9 —

